

AI Critique

HW06 — API Testing | SV **Ninh Van Khai** — **23127060** | De bai muc 10 (200–300 tu)

Sai lam nghiêm trọng nhất của AI ở bài này không phải viết sai một test case, mà là **diễn một bảng kiến thức bằng trí nhớ thay vì đọc tài liệu**. Bởi mã bảo mật SEC-01..07 được AI hiểu theo danh sách lỗ hổng OWASP quen thuộc: SEC-01 là SQL Injection, SEC-05 là leo thang quyền. Bảng thật nói khác hẳn: SEC-01 là mật khẩu không được lưu plaintext, SEC-05 là truy vấn phải dùng parameterized query. Hậu quả: 39 trên 41 test case bảo mật bị gán sai mã.

Đáng chú ý là các test case **van chay dung**: một phép thử SQL Injection và là phép thử SQL Injection dù bị dán nhãn sai. Cái hỏng là bảng do phụ trong báo cáo — nó kháng dinh API-3 đã kiểm SEC-01 tạm cả se, trong khi mã đó không được chạm tới dòng nào. Người đọc không thể tự phát hiện loại sai lầm này.

AI không bắt được vì SEC-01 là một **nhân không tu giải thích**: đọc mã đó không ai đoán được nó nói gì, nên mô hình diễn vào bảng liên tưởng mạnh nhất có sẵn. Bảng thật nằm trong `README.md`, còn `api_specification.md` thì không có bảng nào.

Tôi cũng mắc lỗi cung bản chất: chính tôi viết yêu cầu mọi API phải phụ thuộc vào mã SEC. Yêu cầu đó bất khả thi, và cách duy nhất để đạt được là gán bừa.

Nguyên tắc rút ra: **mọi kháng dinh của AI về một danh sách — mã yêu cầu, tên trường, hàng số — phải được đối chiếu với tài liệu gốc trước khi dùng**. AI suy luận tốt trên nội dung nhưng không đáng tin khi tra cứu danh sách, vì nó không phân biệt được nhớ với đoán.